

LEMBAR KERJA PRAKTIKUM

Intelligent Mobile and Web Application Development

Mata Kuliah	:	Intelligent Mobile and Web Application Development
Kode / SKS	:	TIF-IMWAD / 3 SKS
Program Studi	:	Teknik Informatika
Pertemuan ke-	:	06 dari 16
Topik	:	Implementasi Backend API, Validasi Masukan, Autentikasi JWT, dan Keamanan OWASP API
CPMK	:	CPMK-2 → Sub-CPMK 2.1 & 2.2 (Backend Services, Auth JWT & Keamanan OWASP API)
Dosen Pengampu	:	Edwin Hari Agus Prastyo, S.Kom., M.Kom.
Durasi	:	±50 menit sesi kelas + Tugas Mandiri Lanjutan
Semester / T.A.	:	Ganjil 2025/2026

IDENTITAS MAHASISWA

Nama Mahasiswa :	NIM :
Muhammad Husein Hanafiyah	2395114027

A. Tujuan Pembelajaran

1. Mengimplementasikan arsitektur backend modular 3 lapisan (Router, Service, Repository) berdasarkan kontrak OpenAPI 3.0 (PTM-05).
2. Membangun sistem autentikasi dan otorisasi stateless berbasis JSON Web Token (JWT) dengan OAuth2 Password Flow, refresh token, dan hashing password bcrypt/argon2.
3. Melakukan audit mandiri keamanan API berbasis OWASP API Security Top 10 (2023), menutup celah Broken Object Level Authorization (BOLA), dan menerapkan sanitasi masukan inferensi AI.
4. Melakukan pengujian fungsional API terstruktur menggunakan Postman dan mendokumentasikan Postman Collection yang dapat diimpor ulang.

Pastikan seluruh bahan di bawah telah tersedia sebelum memulai sesi:

Checklist Bahan Awal

☐	openapi.yaml (PTM-05) — spesifikasi kontrak REST API 3.0 yang telah lolos validasi swagger-cli.
☐	models.py (Pydantic/SQLAlchemy) ATAU schema.prisma (Prisma) — skema pemodelan database PTM-05.
☐	Keputusan stack backend: FastAPI (Python) ATAU Next.js API Routes (TypeScript).
☐	Library autentikasi terpasang: python-jose[cryptography], passlib[bcrypt], python-multipart (FastAPI) ATAU jsonwebtoken, bcryptjs, zod (Next.js).
☐	Akses ke endpoint model AI lokal / script mock inferensi AI (dari PTM-05) beserta tool pengujian Postman / Thunder Client.

C. Alur Praktikum Sesi Kelas (±50 Menit)

No	Tahap	Kegiatan	Alokasi
1	Review OpenAPI	Reviu spesifikasi OpenAPI PTM-05; identifikasi endpoint CRUD, Auth, dan AI.	5 mnt
2	Prompt AI Scaffold	Jalankan Prompt D.1; generate arsitektur modular Router-Service-Repository.	15 mnt
3	Prompt AI Auth	Jalankan Prompt D.2; implementasi signup, login bcrypt,	15 mnt

	JWT	token pair, dan protected route.	
4	Prompt AI Audit OWASP	Jalankan Prompt D.3; audit OWASP Top 10, patch BOLA, dan sanitasi input model AI.	10 mnt
5	Uji Postman & Export	Eksekusi uji Postman (happy + error path); ekspor collection ke docs/postman/.	5 mnt
Mandiri	Tugas Lanjutan	Sempurnakan handler inferensi AI ★, sanitasi berkas, laporan owasp-audit.md, push Git.	Di luar kelas

D. Prompt Siap Pakai

D.1 Scaffold Arsitektur Modular Backend (Router → Service → Repository)

Salin prompt di bawah ke alat AI lokal tim. Isi bagian <...> dengan konteks proyek.

[Peran]	Kamu adalah backend engineer senior ahli FastAPI / Next.js API Routes.
[Tugas]	Generate scaffold struktur folder modular (Router → Service → Repository) berdasarkan spesifikasi OpenAPI berikut.
[Konteks]	OpenAPI : <tempel openapi.yaml> Stack : <FastAPI / Next.js API Routes> DB : <PostgreSQL+SQLAlchemy / SQLite+Prisma>
[Format output]	1) Struktur folder lengkap (tree teks modular: routers/, services/, repositories/, models/, core/). 2) Boilerplate kode tiap lapisan untuk 1 resource contoh (/users). 3) Konfigurasi koneksi DB (SQLAlchemy session generator / Prisma client singleton). 4) Template .env.example: DATABASE_URL, SECRET_KEY, ALGORITHM, ACCESS_TOKEN_EXPIRE_MINUTES, MODEL_PATH, SCALER_PATH, MAX_FILE_SIZE_MB.
[Aturan]	- Pisahkan lapisan secara ketat; tidak ada logika bisnis langsung di router. - Repository hanya mengurus query DB; Service menangani validasi bisnis & inferensi. - Semua konfigurasi sensitif wajib lewat env, DILARANG KERAS di-hardcode.

Checklist Scaffold & Modularitas (D.1)

☐	Struktur direktori backend terpisah tegas: routers/controllers, services, repositories/models, core/config.
☐	Koneksi basis data dikelola dengan session lifecycle yang aman (auto-close, pool dikelola, anti connection leak).
☐	File .env.example tersedia lengkap dengan placeholder variabel tanpa mengekspos kredensial rahasia riil.

D.2 Implementasi Autentikasi JWT & Password Hashing

Jalankan prompt ini untuk mengonstruksi sistem autentikasi aman berbasis JWT token pair.

[Peran]	Kamu adalah backend security engineer ahli OAuth2 Password Flow dan JWT.
[Tugas]	Implementasikan autentikasi JWT lengkap pada stack <FastAPI / Next.js> berdasarkan endpoint auth pada spesifikasi OpenAPI.
[Konteks]	Endpoint auth : POST /auth/signup, POST /auth/login, POST /auth/refresh, GET /auth/me Stack : <FastAPI + python-jose + passlib[bcrypt] / Next.js + jsonwebtoken + bcryptjs>
[Format output]	1) Utility hash password bcrypt (hash_password dan verify_password). 2) Generator token pair: Access Token (exp: 30 menit) + Refresh Token (exp: 7 hari).

3) Dependency / middleware protected route (ekstraksi & validasi Bearer JWT token).
4) Handler signup: validasi schema, cek duplikasi email, hashing password, simpan ke repository.
5) Handler login: verifikasi identitas pengguna, cek password hash, kembalikan token pair JSON.
6) Handler refresh: validasi refresh token dari body/header, terbitkan access token baru.
7) Protected endpoint GET /auth/me: kembalikan payload profil pengguna yang sedang login.
[Aturan]
- SECRET_KEY wajib diambil dari environment variable. Password TIDAK BOLEH disimpan plaintext.
- Kembalikan HTTP 401 jika token kadaluarsa/invalid; return 403 jika otorisasi tidak memadai.
- DILARANG menaruh informasi rahasia (password hash, token secret) di dalam claims payload JWT.

Checklist Autentikasi JWT (D.2)

☐	Kata sandi pengguna di-hash menggunakan bcrypt/argon2 dengan salt aman sebelum disimpan ke database.
☐	Alur token pair aktif: Access token berdurasi singkat (30 menit) dan refresh token berdurasi panjang (7 hari).
☐	Endpoint GET /auth/me terproteksi penuh dan menolak request tanpa Authorization: Bearer <token> (HTTP 401).

D.3 Audit Keamanan OWASP API Top 10 & Perbaikan Celah BOLA

Jalankan prompt ini untuk mengidentifikasi celah keamanan dan menghasilkan kode patch pengamanan.

[Peran]	Kamu adalah API Security Auditor berpengalaman standar OWASP API Security Top 10 (2023).
[Tugas]	Audit kode backend berikut terhadap kerentanan OWASP API dan berikan perbaikan konkret.
[Konteks]	Kode yang diaudit : <tempel kode router/service CRUD dan handler inferensi model AI>
Fokus utama	: API1:2023 Broken Object Level Authorization (BOLA/IDOR), API2:2023 Broken Authentication, API4:2023 Unrestricted Resource Consumption, Sanitasi masukan inferensi fitur AI (Prompt Injection / Malicious Upload)
[Format output]	1) Tabel Audit: Endpoint Kerentanan OWASP Tingkat Risiko Kode Patch Status Verifikasi 2) Kode patch konkret (minimal diff) untuk setiap celah otorisasi kepemilikan objek (anti-BOLA). 3) Middleware/helper sanitasi input AI: validasi ukuran file (<=5MB), MIME whitelisting, dan pembersihan string dari karakter injeksi berbahaya.
[Aturan]	- Hanya audit kode yang disediakan; fokus pada pencegahan eksploitasi nyata. - Pada operasi CRUD berparameter ID (GET/PUT/DELETE /items/{id}), WAJIB ada pengecekan: apakah data tersebut benar milik current_user.id? Jika tidak cocok, tolak HTTP 403 Forbidden. - Perbaikan bersifat presisi, tidak menulis ulang arsitektur sistem secara berlebihan.

Checklist Keamanan API OWASP (D.3)

☐	Seluruh endpoint CRUD berparameter ID memiliki verifikasi kepemilikan objek (resource.user_id == current_user.id).
--------------------------	--

☐	Endpoint inferensi AI memiliki validasi ketat ukuran file upload ($\leq 5\text{MB}$) dan whitelisting tipe MIME (cth: image/jpeg, image/png).
☐	Input teks fitur AI disanitasi dari karakter kontrol atau prompt injection berbahaya sebelum diproses oleh model.

D.4 Tabel Iterasi Prompt

Gunakan prompt lanjutan ini bila output AI kurang tepat atau menghasilkan kode bermasalah:

Masalah pada Output AI	Prompt Lanjutan yang Disarankan
Refresh token belum diimplementasikan	Tambah endpoint POST /auth/refresh: terima refresh_token di request body/cookie, validasi signature & expiry, dan kembalikan access_token baru.
Celah BOLA masih terbuka pada CRUD	Pada endpoint GET /predictions/{id}, tambahkan verifikasi: jika prediction.user_id != current_user.id maka raise HTTPException(status_code=403, detail='Akses ditolak').
File upload AI belum divalidasi	Tambahkan validasi upload pada endpoint inferensi: periksa ekstensi file, MIME type hanya (image/jpeg, image/png), dan ukuran maksimum 5MB sebelum disimpan.
Response error 500 saat record kosong	Tangani kasus data kosong pada service/repository: ganti error internal 500 menjadi HTTPException(status_code=404, detail='Data tidak ditemukan').
Secret key JWT masih hardcode	Refaktor konfigurasi: pindahkan SECRET_KEY, ALGORITHM, dan konfigurasi database ke file .env dan baca via pydantic-settings / process.env.

E. Lembar Kerja Isian Mahasiswa

E.1 Daftar Endpoint Backend & Status Implementasi Lapisan

Identifikasi seluruh endpoint yang diimplementasikan dari kontrak OpenAPI PTM-05. Tandai endpoint AI dengan bintang (*).

No	Resource / Endpoint	HTTP Method	Lapisan Terpasang (Router / Svc / Repo)	Status & Cek OWASP Anti-BOLA
1	/api/v1/users/register	POST	Router (user_router.py) → Service (user_service.py) → Repository (user_repository.py)	Aman (Validasi input & enkripsi password bcrypt)
2	/api/v1/users/login	POST	Router (user_router.py) → Service (user_service.py) → Repository (user_repository.py)	Aman (Verifikasi kredensial & penerbitan token pair)
3	/api/v1/histories *	POST	Router (history_router.py) → Service (history_service.py)	Aman (Validasi ukuran file kurang dari 5MB & MIME type whitelist)

			→Repository (history_repository.py)	
4	/api/v1/histories	GET	Router (history_router.py) →Service (history_service.py) →Repository (history_repository.py)	Aman dari BOLA (Filter query berdasarkan user_id == current_user.uid)
5	/api/v1/catalogs	GET	Router (catalog_router.py) →Service (catalog_service.py) →Repository (catalog_repository.py)	Aman (Akses baca publik data referensi edukasi)
6	/api/v1/auth/me	GET	Router (auth_router.py) → Dependency (get_current_user) → Repository	Aman (Dilindungi middleware Bearer Token JWT)

Deskripsi Endpoint Inferensi AI (*) & Mekanisme Validasi/Sanitasi Masukan:

- **Endpoint:** /api/v1/histories (POST)
- **Fungsi & Mekanisme:** Endpoint ini menerima dan menyinkronkan hasil klasifikasi sampah yang telah diproses secara *on-device* oleh model *TensorFlow Lite* di aplikasi seluler. Mekanisme keamanannya mencakup validasi ukuran berkas unggahan maksimal 5 MB untuk mencegah serangan konsumsi sumber daya berlebih (OWASP API4:2023), pemeriksaan jenis MIME (*whitelisting* format image/jpeg dan image/png), serta validasi token otorisasi pengguna.

E.2 Iterasi & Revisi Prompt AI

Catat permasalahan yang muncul pada output AI pertama dan perbaikan prompt lanjutan yang dilakukan tim:

Prompt	Masalah pada Output AI Pertama	Revisi / Prompt Lanjutan yang Digunakan
D.1 Scaffold Modular	Struktur direktori awal masih mencampur logika bisnis langsung di dalam file router tanpa pemisahan lapisan repository yang tegas.	Mempertegas aturan prompt agar pemisahan arsitektur dilakukan ketat: Router hanya menangani HTTP, Service untuk logika bisnis, dan Repository khusus query database.

D.2 Autentikasi JWT	Generator token awal hanya menghasilkan satu token tunggal tanpa masa kedaluwarsa berjenjang untuk sesi keamanan seluler.	Merevisi prompt untuk menerapkan mekanisme <i>token pair</i> terpisah, yakni <i>Access Token</i> berdurasi pendek (30 menit) dan <i>Refresh Token</i> berdurasi panjang (7 hari).
D.3 Audit OWASP & BOLA	Logika pengambilan data riwayat belum membatasi kepemilikan objek, sehingga berisiko rentan terhadap celah <i>Broken Object Level Authorization</i> (BOLA).	Menambahkan aturan audit eksplisit pada prompt agar setiap query CRUD berparameter ID wajib memvalidasi kepemilikan melalui <code>current_user.id</code> .

E.3 Asumsi Teknis & Keputusan Desain Backend [ASUMSI-XX]

Daftarkan setiap asumsi teknis atau keputusan desain yang dihasilkan AI saat menyusun backend:

Kode Asumsi	Isi Asumsi / Keputusan Desain AI	Verifikasi Tim (Diterapkan / Diubah / Ditolak)
ASUMSI-01	Inferensi model AI utama dijalankan secara mandiri di perangkat pengguna (<i>on-device</i> TFLite), sehingga backend hanya bertindak sebagai penerima sinkronisasi riwayat hasil pemindaian.	Diterapkan
ASUMSI-02	Pengelolaan sesi autentikasi menggunakan standar <i>Bearer Token</i> berbasis JSON Web Token (JWT) dengan <i>secret key</i> yang dimuat secara aman dari environment variable (<code>.env</code>).	Diterapkan
ASUMSI-03	Entitas katalog edukasi sampah (<i>Catalog</i>) bersifat statis dan dapat diakses terbuka oleh semua pengguna terautentikasi tanpa memerlukan relasi penguncian kepemilikan data pribadi.	Diterapkan

F. Log Prompt Wajib (ptm-06-prompt-log)

Isi tabel ini selama praktikum berlangsung. Seluruh riwayat prompt wajib disertakan saat pengumpulan tugas.

No	Target Prompt	Alat AI & Versi	Ringkasan Prompt	Kualitas Output (1-5)	Revisi Manual
1	D.1 Scaffold Modular	Gemini (Google)	Meminta pembuatan struktur folder modular backend (Router → Service → Repository) berdasarkan spesifikasi OpenAPI Wastify dengan stack FastAPI dan database SQLite, lengkap dengan konfigurasi koneksi DB dan file <code>.env.example</code> .	5	Menyesuaikan kembali pemisahan logika agar tidak ada kode bisnis yang tercampur langsung di dalam file <i>router</i> .

2	D.2 Autentikasi JWT	Gemini (Google)	Meminta implementasi sistem autentikasi JWT lengkap yang mencakup utility hash password bcrypt, generator <i>token pair</i> (Access Token 30 menit & Refresh Token 7 hari), dependency <i>protected route</i> , serta handler signup, login, refresh, dan endpoint <i>/auth/me</i> .	5	Memastikan bahwa payload token JWT tidak menyimpan informasi rahasia seperti <i>password hash</i> demi keamanan sesi pengguna.
3	D.3 Audit OWASP & BOLA	Gemini (Google)	Meminta audit keamanan kode backend terhadap standar OWASP API Security Top 10 (2023), khususnya pencegahan celah BOLA pada endpoint riwayat serta validasi ukuran file (kurang dari 5MB) dan <i>whitelist</i> MIME type untuk fitur AI.	5	Menambahkan pengecekan eksplisit pada query database riwayat agar mencocokkan <i>user_id</i> dengan <i>current_user.uid</i> secara ketat.
4	Iterasi lanjutan	Gemini (Google)	Melakukan validasi keselarasan lembar kerja isian mahasiswa (LKP) bagian E serta penyusunan log dokumentasi prompt praktikum.	5	Menyempurnakan pemetaan tabel status implementasi lapisan endpoint backend agar sesuai dengan format laporan.

G. Deliverable

File / Artefak	Lokasi di Repositori	Keterangan
Source code backend modular	backend/app/ (atau src/)	Struktur modular Router, Service, Repository, model, dan handler auth
.env.example	Root direktori repositori	Template environment variable aman tanpa nilai rahasia riil
postman-collection.json	docs/postman/	Koleksi request uji API lengkap untuk skenario sukses dan alur error
owasp-audit.md	docs/security/	Laporan audit OWASP API Security Top 10 beserta cuplikan kode patch
ptm-06-prompt-log.md	docs/prompt-log/	Log prompt + iterasi + evaluasi + verifikasi asumsi (WAJIB)
LKP-PTM-06 (lembar ini)	Dikumpulkan via LMS	Dokumen lembar kerja praktikum terisi lengkap format PDF/DOCX

Commit wajib: feat(backend): implement JWT auth, CRUD endpoints, OWASP patches [PTM-06]

PANDUAN PENGUMPULAN TUGAS

H.1 Tenggat Waktu & Kanal Pengumpulan

Unsur	Ketentuan
Batas Pengumpulan	7 (tujuh) hari kalender sejak hari praktikum (H+7), pukul 23.59 WIB.
Platform LMS	Portal LMS resmi kampus / Google Classroom sesuai arahan dosen pengampu.
Nama Folder Submisi	[NIM1-NIM2-NIM3]_PTM06_IMWAD (ganti dengan NIM anggota tim).
Format Berkas	ZIP satu folder: lembar kerja PDF/DOCX + seluruh deliverable + link repositori Git.
Link Repositori	Sertakan URL GitHub/GitLab aktif dalam README.md dan di kolom komentar LMS.

H.2 Berkas yang Wajib Diunggah

Berkas Wajib Pengumpulan

☐	Source code backend — struktur modular (Router/Service/Repository) dapat dijalankan lokal tanpa error.
☐	File .env.example — template variabel lingkungan backend tanpa memuat secret riil.
☐	File postman-collection.json — koleksi uji Postman mencakup alur autentikasi, CRUD, dan AI endpoint.
☐	File owasp-audit.md — laporan hasil audit keamanan OWASP API Top 10 beserta cuplikan kode perbaikan anti-BOLA.
☐	File ptm-06-prompt-log.md — log interaksi AI minimal 2 sesi lengkap dengan catatan iterasi dan evaluasi.
☐	Lembar Kerja Praktikum LKP-PTM-06 — terisi lengkap (Bagian E dan Bagian F wajib diisi).
☐	Tautan repositori Git — commit wajib terverifikasi dengan pesan commit yang telah ditentukan.

H.3 Ketentuan Keterlambatan

Periode	Keterangan	Konsekuensi
H+1 s.d. H+3	Terlambat 1-3 hari	Pengurangan 10 poin dari nilai akhir tugas.
H+4 s.d. H+7	Terlambat 4-7 hari	Pengurangan 25 poin dari nilai akhir tugas.
> H+7	Lebih dari 7 hari	Tugas tidak dinilai; nilai tugas = 0 (nol).

I. Rubrik Penilaian Tugas 6

Aspek Penilaian	Bobot	Indikator Sangat Baik (Skor 90-100)
Implementasi endpoint	30%	Seluruh endpoint OpenAPI terimplementasi secara modular (Router-Service-Repo); format respons dan status HTTP konsisten.
Autentikasi JWT	25%	Alur signup, login, refresh, dan protected endpoint GET /auth/me berfungsi penuh; password di-hash bcrypt; Bearer token tervalidasi.
Keamanan OWASP & BOLA	25%	Celah BOLA tertutup via verifikasi kepemilikan objek (user_id); endpoint AI tersanitasi (ukuran file ≤5MB & MIME valid); env terpisah.
Pengujian Postman	10%	Postman collection lengkap, mencakup alur sukses (200/201) dan alur kegagalan (401/403/404/422); siap diimpor dan diuji ulang.

Prompt log & etika AI	10%	Log prompt mencakup minimal 2 sesi interaksi AI beserta evaluasi kualitas; asumsi teknis diverifikasi tim; deklarasi ditandatangani.
----------------------------------	-----	--

J. Referensi

- OWASP API Security Top 10 2023 — <https://owasp.org/API-Security/>
- FastAPI Security Tutorial — <https://fastapi.tiangolo.com/tutorial/security/>
- python-jose Documentation — <https://python-jose.readthedocs.io/>
- Next.js Route Handlers & Middleware — <https://nextjs.org/docs/app/building-your-application/routing/middleware>
- Outline PPT PTM-06 IMWAD — Slide B-F (Arsip LMS Dosen)
- Panduan Prompt AI 5 Bagian — 00-index-praktikum-prompt-ai-imwad-ptm-05-16.md